

Arquitetura SCSl: Borda, Domínio & Criptografia

Relatório Executivo — Fases 3 e 4 (Cloudflare & SSL/TLS)

Resumo Executivo

Este documento consolida as implementações realizadas nas Fases 3 e 4 do projeto **Estudo de Arquitetura de Sistemas Inteligentes (SCSI)**, estabelecendo um perímetro de segurança de borda robusto e criptografia ponta a ponta utilizando Cloudflare e Traefik.

Status de Segurança: Grade A+ (Qualys SSL Labs)

A arquitetura foi validada pelos 4 subagentes especialistas, atingindo o mais alto nível de segurança cibernética e mitigação de ameaças automatizadas.

1. Topologia de Borda (Cloudflare)

A arquitetura adota o modelo *Triple-Hop Anycast*, onde o tráfego é roteado pelo PoP mais próximo da Cloudflare antes de atingir a VPS Hostinger.

- **Proxy Laranja (Ativo):** Ocultação do IP real da VPS.
- **DNS SecDNS:** Registros A (apex) e CNAME (www, api, app, traefik, flower) configurados.
- **Blindagem de Origem (ADR 008):** UFW e Traefik configurados para aceitar conexões nas portas 80/443 exclusivamente dos blocos IPv4 e IPv6 oficiais da Cloudflare.

2. Mitigação de Ameaças (WAF & DDoS)

Regras estritas foram implementadas para garantir disponibilidade e resiliência da infraestrutura:

Camada	Tecnologia Aplicada
WAF (Wirefilter)	Proteção OWASP Core, bloqueio de scanners de vulnerabilidade e verificação de integridade de browser via Turnstile.
DDoS L7	Under Attack Mode via API para surtos de tráfego volumétrico.
Rate Limiting	Políticas granulares: 5 req/min (Auth), 10 req/min (IA/GPU), 60 req/min (API Geral), 20 req/min (Admin).
Bot Management	Bloqueio sumário de web scrapers agressivos e crawlers de IA (GPTBot, Bytespider, CCBot).

3. Arquitetura Criptográfica (SSL/TLS)

O ambiente opera sob mandato corporativo de tráfego seguro (ADR 010):

Protocolo de Criptografia:

O modo *Flexible* foi categoricamente rejeitado devido à vulnerabilidade Man-in-the-Middle. O sistema opera exclusivamente em modo **Full Strict** (criptografia ponta a ponta com validação estrita do Origin CA).

- **Cloudflare Origin CA:** Certificado de 15 anos instalado no Traefik (dispensa renovação periódica ACME/Let's Encrypt na VPS).
- **Protocolos Ativos:** TLS 1.2 (mínimo), TLS 1.3 (preferencial) e HTTP/3 (QUIC/UDP 443).
- **Cifras (AEAD):** Configuração restrita a cifras modernas como x25519, AES_256_GCM e CHACHA20_POLY1305.

- **HSTS:** Strict-Transport-Security configurado para 1 ano (31.536.000 segundos) com preload.

4. Ingress e Roteamento Interno (Traefik v3.1)

O roteamento para o Docker Swarm foi modelado declarativamente, incluindo correções técnicas críticas apontadas pela bancada de especialistas:

- Middlewares de compressão configurados com exclusão para `text/event-stream`, protegendo streams e Server-Sent Events (SSE) de IA.
- Timeouts estendidos (300s) configurados para acomodar inferência e orquestração de LLMs (LangGraph).
- BasicAuth (bcrypt) com IP AllowList para os dashboards do Traefik e Celery Flower.
- Injeção do X-Forwarded-Proto via Traefik.